

Appendix A: Examination Procedures

Examination Objective

Examiners should use these procedures to determine the quality and effectiveness of the institution's management of IT. Examiners should also use these procedures to measure the adequacy of the institution's ITRM process, including management awareness and participation, risk assessment, policies and procedures, reporting, ongoing monitoring, and follow-up.

These examination procedures (also known as the work program) are intended to assist examiners in determining the effectiveness of the institution's IT management process. Examiners may choose, however, to use only particular work steps of the following examination procedures based on the size, complexity, and nature of the institution's business. Examiners should use these procedures to measure the adequacy of the institution's cybersecurity risk management processes.

Objective 1: Determine the appropriate scope and objectives for the examination.

1. Review past reports for outstanding issues or previous problems. Consider the following:
 - a. Regulatory reports of examination.
 - b. Internal and external audit reports.
 - c. Internal or independent tests or reviews of controls (e.g., penetration tests, business continuity reviews, and third-party management reviews).
 - d. Regulatory and audit reports on service providers.
2. Review management's response to issues raised during, or since, the last examination. Consider the following:
 - a. Adequacy and timing of corrective action.
 - b. Resolution of root causes rather than just specific issues.
 - c. Existence of any outstanding issues.
 - d. Whether management has taken positive action toward correcting exceptions reported in audit and examination reports.
 - e. Independent review of resolution and reporting of resolution to the audit committee.
3. Interview management and review responses to pre-examination information requests to identify changes to the technology infrastructure or new products and services that might increase the institution's risk. Consider the following:
 - a. Products or services delivered to either internal or external users.
 - b. Current network diagrams and data flow diagrams, including changes to configuration or components.
 - c. Hardware and software inventories.
 - d. Loss or addition of key personnel.
 - e. Inventories of third-party providers and software vendors.

- f. Organizational charts that include reporting relationships between business units and control functions (e.g., enterprise risk management, ITRM, and internal audit).
- g. Credit or operating losses primarily attributable (or thought to be attributable) to IT (e.g., system problems, inadequate controls, improperly implemented changes to systems, and fraud resulting from cybersecurity attacks, such as account takeover).
- h. Changes to internal business processes.
- i. Internal reorganizations.

Objective 2: Determine whether the board of directors oversees and senior management appropriately establishes an effective governance structure that includes oversight of IT activities.

1. Review the institution's governance structure to determine the oversight of IT activities and verify that it includes the following:
 - a. Board sets the tone and direction for the institution's use of technology.
 - b. IT risks are adequately identified, measured, and mitigated.
 - c. Board approval of the information security program and other IT-related policies.
 - d. Board members are familiar with IT activities.
2. Review the activities performed by the board or a committee of the board to determine the effectiveness of IT oversight. Specifically, review whether the board or a committee of the board appropriately does the following:
 - a. Reviews and approves an IT strategic plan that aligns with the overall business strategy and includes an information security strategy to safeguard against ongoing and emerging threats, including cybersecurity threats.
 - b. Oversees the institution's adoption of effective IT governance processes.
 - c. Oversees management processes for approving third-party providers that include an assessment of financial condition and IT security posture of the third party, including on cybersecurity.
 - d. Has an oversight process that includes receiving updates on major projects, IT budgets, IT priorities, and overall IT performance; and has an approval process for critical projects and activities.
 - e. Reviews the adequacy and allocation of IT resources in terms of funding and personnel.
 - f. Approves a policy to escalate and report significant security incidents to the board, steering committee, government agencies, and law enforcement, as appropriate.
 - g. Holds management accountable for the identification, measurement, and mitigation of IT risks.
 - h. Provides for independent, comprehensive, and effective audit coverage of the IT program.
3. Determine whether the board does the following:
 - a. Delegates monitoring for specific IT activities, as appropriate, to a steering committee.
 - b. Provides a credible challenge to management decisions.

- c. Receives regular reports regarding operations.
 - d. Directs management to maintain an institution-wide view of technology and the business processes supported by technology.
4. Review the membership list of board, steering committee, and/or relevant management committees established to review IT activities. Determine whether board, senior management, lines of business, audit, and IT personnel are represented appropriately, and whether regular meetings are held and minutes are maintained.
 5. Review the minutes of the board of directors and relevant committee meetings for evidence of board support and supervision of IT activities.
 6. If the board delegates certain activities regarding the oversight of IT to a committee, review the membership, responsibilities, and activities of the committee. Specifically, determine whether the committee does the following:
 - a. Maintains a charter that defines its responsibilities.
 - b. Has a defined mission to assist the board in IT oversight.
 - c. Has decision-making authority.
 - d. Receives appropriate management information from IT, lines of business, and external sources.
 - e. Coordinates and monitors IT resources.
 - f. Determines whether there is adequate training, including cybersecurity training, for institution staff.
 - g. Reports to the board on the status of IT activities to enable the board to make decisions.
 - h. Receives reports on IT to remain informed on risk.
 - i. Is responsible for effective strategic IT planning, oversight of IT performance, and aligning IT with business needs.
 7. Review the board of directors and management oversight program for IT. Determine whether the board has effective oversight of IT. Determine whether the board oversees and management implements the following:
 - a. Processes and procedures that meet objectives of governing IT policies.
 - b. Appropriate policies for information security, including cybersecurity risk management processes, and other relevant IT policies.
 - c. Policies that result in compliance with applicable regulatory requirements.
 - d. Controls over risks associated with system development and acquisition.
 - e. Process for business continuity planning.
 8. Review IT management and determine whether management performs the following:
 - a. Implements effective IT governance and IT risk management processes, including those that relate to cybersecurity.
 - b. Reviews, understands, approves, and provides for at least annual reviews of ITRM processes.

- c. Assesses the institution's inherent IT risks across lines of business and ensures IT risks are included in enterprise-wide risk assessments.
 - d. Provides regular reports to the board on IT risks, IT strategies, and IT changes.
 - e. Coordinates priorities between the IT department and lines of business.
 - f. Establishes a formal process to obtain, analyze, and respond to information on threats and vulnerabilities by developing a repeatable threat intelligence and collaboration program.
 - g. Ensures that hiring and training practices are governed by appropriate policies to maintain competent and trained staff.
9. Review the roles and responsibilities of all levels of management, including executive management, CIO or CTO, CISO, IT line management, and IT business unit management, to ensure that there is a clear delineation between management and oversight functions and operational duties.
10. Review the corporate and IT departmental organization charts to determine whether they show the following:
 - a. IT management reports directly to senior management, with appropriate reporting directly to the board, as needed.
 - b. The IT department's responsibilities are appropriately segregated from business processing activities.
11. Review the institution's structure to determine whether the board established the following:
 - a. The organizational structure provides for effective IT support throughout the institution, from IT management up through senior management and the board.
 - b. Defined roles and responsibilities for key IT positions, including executive management (CEO and COO, and often CIO or CTO), and CISO.
 - c. An appropriate and effective executive management team or positions, such as CEO and COO, to assist in the oversight and management of IT.
 - d. A defined and functioning role for the CIO or CTO to focus on strategic IT issues and the overall effectiveness of the IT function.
 - e. A CISO or information security officer position responsible for the management and mitigation of information security risks.
 - f. Involvement of frontline management in the IT oversight process.
 - g. Integration of business line managers into the IT oversight process.
12. Determine whether the reporting structure ensures that the CISO has the appropriate authority to carry out its responsibilities and that there are no conflicts of interest in the ability of the CISO to make decisions in line with the risk appetite.
13. Determine management's need for, or effectiveness in, selecting and implementing appropriate EA and assess whether the EA program serves the institution's needs, complexity, and future technology plans.

Objective 3: *As part of the ITRM structure, determine whether financial institution management has defined IT responsibilities and functions. Verify the existence of well-defined responsibilities and expectations between risk management and IT functional areas, such as information security, project management, business continuity, and information systems reporting.*

1. Review the institution's established lines of authority for enforcing and monitoring controls.
2. Determine whether management has a board-approved written information security program and verify that it is maintained and updated according to regulatory requirements.
3. Determine whether the institution has a project management function appropriate for the complexity of the institution, and verify that this function contains the appropriate elements.
4. Determine whether the institution maintains an adequate and up-to-date enterprise-wide business continuity plan. Determine whether the board oversees implementation and approves policies related to business continuity planning.
5. Determine whether the institution has a well-defined role for the implementation and use of information systems reporting and that it produces accurate and useful reports. Determine the effectiveness of the reports used by senior management or relevant management committees to supervise and monitor the following IT functions:
 - a. Management reports that provide the status of software development and maintenance activities.
 - b. Performance and problem reports prepared by internal user groups.
 - c. System use and planning reports prepared by operating managers.
 - d. Internal and external audit reports of IT activities.
6. Review information systems reports for management, and determine whether they provide the information necessary to help manage the institution effectively. Determine the following:
 - a. The information systems reports facilitate the management of the business.
 - b. The process and results are effective.
 - c. Data and information provided to the board and senior management allow them to make strategic decisions.
 - d. The information systems reports provide key risk and performance trends, indicators, and performance against risk tolerances.
 - e. The institution has effective controls procedures in place to ensure that information is correct and relevant.
 - f. The systems and reporting meet the five elements of effective reporting: timeliness, accuracy, consistency, completeness, and relevance.
 - g. The information systems reports are appropriate for the size and complexity of the institution.

Objective 4: Determine the adequacy of the institution's IT operations planning and investment. Assess the adequacy of the risk assessment and the overall alignment with the institution's business strategy, including planning for IT resources and budgeting.

1. Determine whether the board oversees and management considers the following when formulating the institution's overall business strategy:
 - a. Risk assessment, priority, and mitigation across the institution.
 - b. IT strategic plans.
 - c. Major projects in process or planned.
 - d. Third-party relationships, including the third party's current and future plans (e.g., changes in strategy and products offered) and service or security issues that may affect the institution.
 - e. Staffing levels sufficient to complete tasks as scheduled.
 - f. IT operating costs.
 - g. IT contingency planning and business recovery.
2. Review the strategic plan for IT activities. Determine whether the goals and objectives are consistent with the institution's overall business strategy. Document significant changes made since the previous examination that affect (or any planned changes that may affect) the institution's organizational structure, hardware or software configuration, and overall operational goals. Determine the following:
 - a. Business needs are realistic.
 - b. IT has the ability to meet business needs.
 - c. The plan addresses long-term (three- to five-year horizon) goals and allocation of resources.
 - d. The plan incorporates the entire IT environment.
 - e. The plan lists strategic initiatives and considers all necessary factors around those initiatives.
 - f. The plan includes tactical plans to achieve strategic goals.
 - g. The plan explains trends and issues of potential impact.
 - h. The plan incorporates clearly defined goals and metrics.
 - i. The planning process adjusts for new or changing risks.
 - j. IT Management participates in the development of the IT strategic plan.
 - k. There is review of and credible challenge to the plan.
3. Determine whether the institution has adequate tactical and operational IT plans to support the larger IT strategic plan.
4. Determine whether the board or board committee reviews and approves the following:
 - a. Information security risk assessment, including cybersecurity.
 - b. Short- and long-term IT tactical, operational, and strategic plans.
 - c. Resource allocation (e.g., major hardware or software acquisition and project priorities).
 - d. Reported status of major projects.

- e. IT budgets and current operating cost and the allocation of IT resources.
5. Determine the effectiveness of management's process to fund IT resources to meet the current operational needs of the institution. Assess whether management considers the following IT resources:
 - a. Infrastructure.
 - b. Hardware.
 - c. Operating software.
 - d. Application software.
 - e. Personnel.
6. Determine whether the board reviews management's budget plans. Determine the effectiveness of the budget process to estimate and control the institution's activities.
7. If the institution uses third-party providers, determine whether management:
 - a. Verifies that the third-party providers can continue to support current contract requirements and future changes (e.g., that the third party has a satisfactory financial condition).
 - b. Has a process to assess whether a third party's actions may negatively affect the institution (e.g., a review of the third-party plans to continue offering the necessary products or services contracted by the institution).
 - c. Has an effective ongoing monitoring process of its third-party providers.

Objective 5: Along with the IT audit and compliance departments, the HR department can serve as an influencing function for IT. Determine the adequacy of the institution's HR function to ensure its ability to attract and retain a competent workforce.

1. Determine the institution's ability to attract and retain a competent workforce and the ability of HR management to effectively meet the requirements for IT and the lines of business that IT supports.
2. Identify key IT positions, review biographical data (e.g., résumés and training and development records), and determine the following:
 - a. Job descriptions are reasonable and represent actual practice.
 - b. Employees have appropriate qualifications.
 - c. Staffing levels are appropriate.
 - a. There are provisions for management succession that provide for an acceptable transition in the event of the loss of a key IT manager or staff member.
 - b. Backup personnel are identified and trained.
3. Review and evaluate written job descriptions to ensure that management performs the following:

- a. Clearly defines the authority, responsibility, and technical skills required.
 - b. Maintains updated job descriptions in writing.
4. Determine whether the HR function has processes for compensation planning, performance reviews, knowledge transfer mechanisms, training, and mentoring.
5. Determine whether the financial institution has a process to ensure that staff has the requisite expertise to fulfill its roles. Review the adequacy of the process.
6. Determine the adequacy of the institution's training programs. Determine whether the institution has or supports the following:
 - a. Internal or external training programs.
 - b. Certification programs.
 - c. Training processes that support the goals and objectives of the institution.
7. Review turnover rates of IT staff and discuss staffing and retention issues with IT management, or review turnover rates of IT management and discuss with senior management. Identify root causes of any staffing or expertise shortages, including compensation plans or other retention practices.
8. If IT staff members have duties in other departments, determine the following:
 - a. Management is aware of the potential conflicts such duties may cause.
 - b. Conflicting duties are subject to appropriate supervision and compensating controls.

Objective 6: Evaluate management's review and oversight of IT controls, including the other influencing functions of IT audit and compliance.

1. Consult with the examiner reviewing audit or IT audit to determine the adequacy of IT audit coverage and management's responsiveness to identified weaknesses.
2. Determine whether the board provides for the necessary expertise in the audit department and that audit coverage is comprehensive, timely, and independent. Assess whether the board requires audit reporting directly to the board or a designated committee.
3. Determine whether the board, or its committee, has appropriate oversight of audit through the following:
 - a. Audit risk assessment and audit plan.
 - b. Audit review activities.
 - c. Audit reports with identified weaknesses.
 - d. Management's responses and corrective actions to audit issues.
 - e. Updates on any audit concerns and the status of issues.

4. Determine whether the board, or a board committee, is responsible for overseeing performance and compensation for the audit department.
5. Determine whether the compliance function has involvement in the institution's review oversight process, and assess the adequacy of its involvement.
6. Determine whether compliance staff reviews new products, systems, applications, or changes to evaluate compliance with applicable laws and regulations.

Objective 7: Determine whether the institution's risk management program facilitates effective risk identification and measurement and provides support for risk decisions within ITRM.

1. Determine whether the institution has a risk management program and whether the program includes an integrated approach for enterprise-wide risk management, including identification, measurement, mitigation, monitoring, and reporting of risk. If applicable, determine whether the structure conforms to regulatory requirements.
2. Determine the effectiveness of the risk management program by reviewing whether it receives appropriate direction and support from the board and senior management.
3. Determine the following:
 - a. The board of directors has defined its risk appetite and the institution's risk tolerance levels.
 - b. The board of directors has applied sufficient resources to achieve its risk appetite and remain within the institution's risk tolerance levels.
 - c. Management has committed to support the board's risk decisions.
4. Determine whether the institution maintains a risk assessment process to perform the following:
 - a. Identify risks and threats from both internal and external sources.
 - b. Develop or update policies within the risk management function to guide risk measurement activities.
 - c. Ensure the existence of a process to promote sound understanding and analysis of threats, events, assets, and controls.
 - d. Maintain processes within the risk management function to help make risk mitigation decisions.
 - e. Determine the entities that should have involvement in that decision-making process.
 - f. Ensure that the board and management understand the risk categories.

Objective 8: Determine whether the board of directors oversees and senior management proactively mitigates operational risk.

1. Review the institution's management of operational risk, and verify that the risk management process includes aspects of operational risk across the institution, including the following:
 - a. Back-office operations and transaction processing.
 - b. Customer service.
 - c. Systems development and support.
 - d. Internal controls and processes.
 - e. Capacity planning.
2. Determine whether the institution's management of operational risk incorporates an enterprise-wide view of IT and business processes that are supported by technology.
3. Assess whether IT management maintains an active role in the institution's strategic planning to align IT with established business goals and strategies. Assess whether effective IT controls exist throughout the institution, either through direct oversight or by holding lines of business accountable for IT-related controls.
4. Determine whether IT management participates in the enterprise-wide risk management process to identify and measure risk from the use of IT, support decisions on how to mitigate the risks, implement the mitigation decisions, and monitor and report on the resulting outcomes.

Objective 9: Determine whether management implements an ITRM process that supports the overall enterprise-wide risk management process.

1. Review the role of IT management in the risk management process and identify whether it is supportive and collaborative to the overall process.
2. Determine whether the ITRM process includes the following:
 - a. A risk identification process to identify risks to information assets within the institution and information assets controlled by third-party providers.
 - b. A risk measurement process using an evidence-based approach to measure the level of risk and determine if it is in line with the board's risk appetite.
 - c. A risk mitigation process to ensure that management mitigates the risks to an acceptable residual risk level.
 - d. A risk monitoring and reporting process to monitor changing risk levels and report the results of the process to the board and senior management.
3. Determine whether the ITRM process includes the following:
 - a. Is regularly updated with a frequency appropriate for the pace of change.
 - b. Aligns IT and business objectives.